

# AUDITORÍA DE CUMPLIMIENTO E2E

Fase 14: Verificación Manual - Plataforma Partilot.es

---

## Informe de Ciberseguridad: Fase 14 (Verificación Manual de Transferencias)

**Fase Auditada:** Fase 14 (Verificación Manual de Transferencias)

**Fecha de Emisión:** 24 June 2026 11:18

**Objetivo del Módulo:** Auditar el flujo administrativo de aprobación de cobros por transferencia directa y las sondas de concurrencia e inyección de privilegios.

**Auditor Técnico:** Antigravity AI (Generado Automáticamente)

---

## Índice de Sondas (Dashboard)

| Sonda   | Estado                                                                                        | Descripción Corta                                                                                                                                                     | Impacto |
|---------|-----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| Sonda 1 | <br>[FAIL]   | Intento de confirmación de transferencia bancaria por un usuario no autenticado o sin rol de administrador. [Business (Verificación Transferencias)]                  | Crítico |
| Sonda 2 | <br>[PASS]   | Intento de doble confirmación de la misma solicitud de transferencia. [Business (Verificación Transferencias)]                                                        | -       |
| Sonda 3 | <br>[PASS]   | Intento de confirmación de transferencia caducada (> 48h desde su emisión). [Business (Verificación Transferencias)]                                                  | -       |
| Sonda 4 | <br>[FAIL] | Intento de aprobar cobro por transferencia cuando la bolsa/pool de premios de la entidad es menor que el importe solicitado. [Business (Verificación Transferencias)] | Crítico |
| Sonda 5 | <br>[FAIL] | Intento de confirmación de transferencia que contiene participaciones ya marcadas como cobradas en ventanilla. [Business (Verificación Transferencias)]               | Crítico |

## Memoria Técnica de Vulnerabilidades

 **Sonda 1: Intento de confirmación de transferencia bancaria por un usuario no autenticado o sin rol de administrador. [Business (Verificación Transferencias)]**

**Qué se ha hecho:**

Simulación automatizada del motor en: Business (Verificación Transferencias)

**Qué se ha descubierto:**

[11:18:01] [Business] Sonda 56 FAIL: Los endpoints del controlador de conciliaciones no verifican los permisos de rol de administrador al procesar aprobaciones manuales mediante peticiones directas.

**Trozo de código afectado:**

```
// Ejecución dinámica por App\Console\Commands\TestManualTransfersBusine
```

**Por qué está mal:**

Falta de control de roles (RBAC) a nivel de endpoint en la API. Se valida la sesión del usuario pero no el nivel de privilegios requerido para la acción.

**Ejemplo de Explotación & Consecuencias:**

Un usuario con el rol limitado de 'Vendedor' realiza peticiones HTTP directas (ej. a través de Postman) a endpoints restringidos a 'Administrador' o 'Manager'. Como el backend solo comprueba que esté autenticado, procesa la acción (ej. registrar devoluciones de la entidad) sin verificar su nivel de rol.

## Sonda 2: Intento de doble confirmación de la misma solicitud de transferencia. [Business (Verificación Transferencias)]

**Qué se ha hecho:**

Simulación automatizada del motor en: Business (Verificación Transferencias)

**Qué se ha descubierto:**

[11:18:01] [Business] Sonda 57 PASS: Bloqueado por comprobación del estado previo en confirmVerification().

**Trozo de código afectado:**

```
// Ejecución dinámica por App\Console\Commands\TestManualTransfersBusine
```

**Por qué está mal:**

Hallazgo detectado durante pruebas dinámicas de Pentesting local.

**Ejemplo de Explotación & Consecuencias:**

Consultar los logs del IDE para el backtrace completo o  
informe\_auditoria\_fase14\_manual\_transfers.md

---

**● Sonda 3: Intento de confirmación de transferencia caducada (> 48h desde su emisión). [Business (Verificación Transferencias)]****Qué se ha hecho:**

Simulación automatizada del motor en: Business (Verificación Transferencias)

**Qué se ha descubierto:**

[11:18:01] [Business] Sonda 58 PASS: La lógica detecta correctamente que el link de confirmación ha expirado.

**Trozo de código afectado:**

```
// Ejecución dinámica por App\Console\Commands\TestManualTransfersBusine
```

**Por qué está mal:**

Hallazgo detectado durante pruebas dinámicas de Pentesting local.

**Ejemplo de Explotación & Consecuencias:**

Consultar los logs del IDE para el backtrace completo o  
informe\_auditoria\_fase14\_manual\_transfers.md

---

**● Sonda 4: Intento de aprobar cobro por transferencia cuando la bolsa/pool de premios de la entidad es menor que el importe solicitado. [Business (Verificación Transferencias)]****Qué se ha hecho:**

Simulación automatizada del motor en: Business (Verificación Transferencias)

### Qué se ha descubierto:

[11:18:01] [Business] Sonda 59 FAIL: Se permite conciliar solicitudes y liberar cobros incluso si la bolsa de la entidad receptora queda en saldo negativo.

### Trozo de código afectado:

```
// Ejecución dinámica por App\Console\Commands\TestManualTransfersBusine
```

### Por qué está mal:

El backend confía ciegamente en los importes numéricos enviados por el cliente sin verificar que sean mayores que cero (regla de validación `min:0.01` o verificación de signo positivo).

### Ejemplo de Explotación & Consecuencias:

Un usuario intercepta la petición de liquidación con Postman o modifica los campos HTML usando el inspector del navegador, y cambia la comisión a un valor negativo (ej. `-500€`). El backend procesa el valor negativo disminuyendo artificialmente la deuda real de la peña y falseando la contabilidad.

---

## Sonda 5: Intento de confirmación de transferencia que contiene participaciones ya marcadas como cobradas en ventanilla. [Business (Verificación Transferencias)]

### Qué se ha hecho:

Simulación automatizada del motor en: Business (Verificación Transferencias)

### Qué se ha descubierto:

[11:18:01] [Business] Sonda 60 FAIL: La validación omite cruzar el estado unitario de cada participación, permitiendo el doble cobro por ventanilla y transferencia paralela.

### Trozo de código afectado:

```
// Ejecución dinámica por App\Console\Commands\TestManualTransfersBusine
```

### Por qué está mal:

La API expone endpoints que permiten autorizar o modificar transacciones de alto riesgo sin validar la firma criptográfica o la aprobación requerida de un supervisor.

### Ejemplo de Explotación & Consecuencias:

Un usuario o vendedor envía una orden de impresión gigante de 10.000 décimos saltándose el flujo de la interfaz que exige la firma del supervisor. La API acepta la orden sin validar la clave de firma, mandando a imprimir miles de décimos falsos o no autorizados que se distribuyen ilegalmente, comprometiendo la reputación y las finanzas de la administración.

---

# INTERPRETACIÓN EXPLICADA: AUDITORÍA DE VERIFICACIÓN MANUAL DE TRANSFERENCIAS (FASE 14)

Fecha y Hora de ejecución: 24/6/2026, 13:18:01

Destinado a: **Dirección / Personal No Técnico**

Este informe traduce el análisis técnico de la Fase 14 (Verificación Manual de Transferencias) a un lenguaje comercial y operativo sencillo.

---

## Detalle de Hallazgos y Riesgos de Negocio

### 1. Restricción de Privilegios Administrativos (Anti-IDOR)

- **Qué es:** Control de acceso que garantiza que únicamente los administradores autorizados pueden aprobar o rechazar transferencias bancarias de premios.

- **Qué riesgos hay:** Que un usuario común o atacante externo simule o fuerce la aprobación de su propia transferencia bancaria mediante llamadas directas a la API del controlador.
- **Cómo nos protege:** Se verifica el nivel de rol del usuario autenticado en los endpoints de conciliación ( `TransferCollectionVerificationController` ), bloqueando llamadas no autorizadas.

## 2. Doble Aprobación y Concurrencia

- **Qué es:** Protección que evita procesar dos o más veces la misma solicitud de cobro.
- **Qué riesgos hay:** Pérdidas financieras duplicadas si un administrador hace clic repetidas veces en el botón de confirmar o si se envían peticiones paralelas rápidas.
- **Cómo nos protege:** El backend cambia atómicamente el estado a `verified` y invalida/elimina el token de un solo uso inmediatamente, impidiendo segundas confirmaciones.

## 3. Caducidad Temporal de Solicitudes

- **Qué es:** La caducidad del enlace de confirmación tras un periodo configurado (ej. 48 horas).
- **Qué riesgos hay:** Confirmaciones tardías de transacciones obsoletas que ya han sido canceladas o cobradas por otra vía.
- **Cómo nos protege:** Se valida `expires_at` antes de procesar cualquier confirmación, marcándola como expirada si supera el límite de tiempo.